

PHISHING EMAIL ANALYSIS REPORT

SOC Analyst Training Challenge

Case Reference	Challenge 1 challenge1.eml
Analyst	Michael LERAMO
Organization	Mighty Solutions, Inc.
Date	April 2026
Classification	Confidential — Training Exercise
Status	COMPLETED

Submitted to the Security Team Phishing Mailbox for Review

Incident Overview

An account executive at Mighty Solutions, Inc., Dana Derringer, received a suspicious warning email claiming her online account access had been disabled due to unusual activity. Dana immediately noticed something was off; she could still log into all her business platforms and inbox without any issues.

This contradiction was the first indicator that the email was not legitimate. Dana forwarded the email to the security team's phishing mailbox for review. As the assigned SOC Analyst, I performed a full analysis on challenge1.eml to determine whether this was a phishing attempt and to document all findings.

Phase 1: Visual Inspection in Thunderbird

Why This Phase Matters: Visual Inspection

I wanted to see what Dana saw. Before pulling the raw header, I opened the email in Thunderbird to get the attacker's perspective. Social engineering works on humans, not machines. So I looked at it the way a human would first.

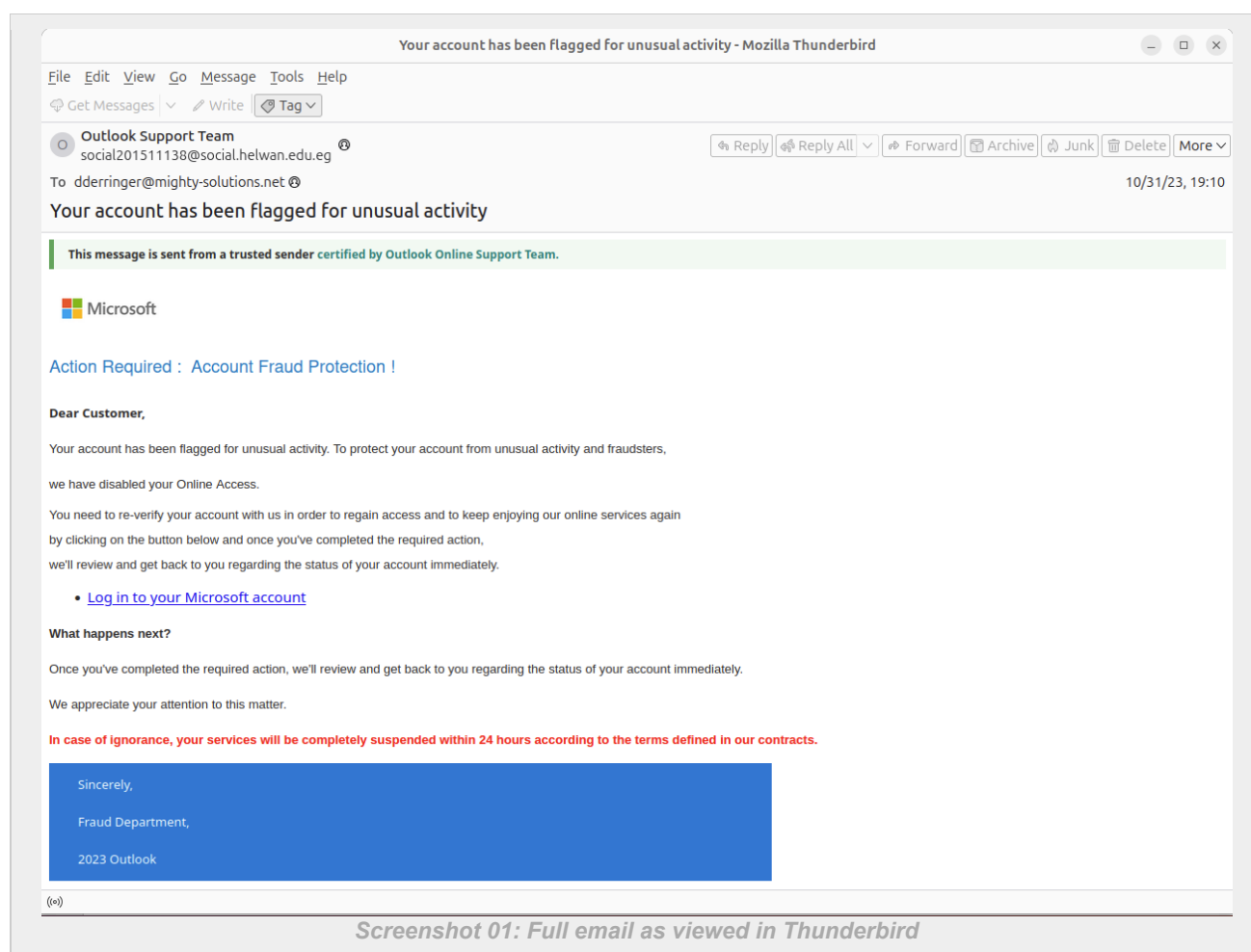
I opened the email using Thunderbird with the following command:

```
thunderbird challenge1.eml
```

Several things stood out immediately:

- Microsoft branding and logo used to build false trust before the victim reads a single word
- Display name: 'Outlook Support Team' most people never look past the name in their inbox
- Subject line engineered to create panic before the email is even opened
- Body claims access is disabled and that one click fixes it that's the hook
- 24-hour suspension threat manufactured urgency to stop the victim from thinking clearly
- Signed off as 'Fraud Department, 2023 Outlook' that department does not exist
- Greeting: 'Dear Customer' Microsoft knows your name. This confirms it's a bulk campaign

Each of these tactics serves one purpose: make the victim act before they think. That is social engineering. None of this is how a legitimate Microsoft communication behaves.



Phase 2: Email Header and Sender Analysis

Why This Phase Matters: Email Header Analysis

The header is where the attacker loses control. They can fake the display name and the From address, but they can't change what the receiving server stamped the real IP, the routing path, the authentication results. That's what I was looking for.

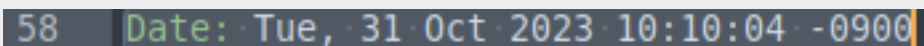
I opened the raw email file in Sublime Text to read the complete header:

`subl challenge1.eml`

Finding 1: Date and Time of Email Delivery

I searched for the Date: header. The sending mail server stamps this at the moment of dispatch. It gives a precise timestamp of when the attack was launched useful for incident timelines and correlating with other logs.

Date / Time	Tue, 31 Oct 2023 10:10:04 -0900
-------------	---------------------------------

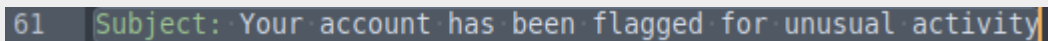


Screenshot 02: Date header in Sublime Text

Finding 2: Subject of the Email

Reading the Subject: in the raw header not just in Thunderbird confirms the exact string the attacker sent. It rules out any display formatting that might hide encoding tricks or unusual characters.

Subject	Your account has been flagged for unusual activity
---------	--

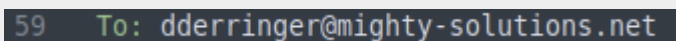


Screenshot 03: Subject header in Sublime Text

Finding 3: Recipient of the Email

The To: header confirms the intended recipient. This matters for scoping I need to know who was targeted, and whether other recipients may exist.

Sent To	dderringer@mighty-solutions.net
---------	---------------------------------



Screenshot 04: To header in Sublime Text

Finding 4: Who the Email Claims to Be From (Display Name)

The From: field has two parts: a display name and the actual email address. Most email clients show only the display name. That's exactly what attackers rely on. The victim sees a trusted name and never digs further. I needed to see both parts.

Display Name (Claimed Identity)	Outlook Support Team
---------------------------------	----------------------

```
60 From: Outlook Support Team
```

Screenshot 05: From display name in Thunderbird and Sublime Text

Finding 5: Sender's Actual Email Address

Once I expanded the From: header in full, the actual sending address was right there. It had no connection to Microsoft. This is the most immediate confirmation of spoofing the claimed identity and the real sender are two completely different things.

Actual Sender Address	social201511138@social.helwan.edu.eg
-----------------------	--------------------------------------

```
60 From: Outlook Support Team <social201511138@social.helwan.edu.eg>
```

Screenshot 06: Full From: header showing actual email address in Sublime Text

Finding 6: Bounce Email Address (Return-Path)

The Return-Path shows where failed delivery notifications go. In plain terms it's the address the attacker actually controls. If the display name says Microsoft but the Return-Path is somewhere else entirely, the infrastructure doesn't match the claim.

Return-Path (Bounce Address)	social201511138@social.helwan.edu.eg
------------------------------	--------------------------------------

```
68 Return-Path: social201511138@social.helwan.edu.eg
```

Screenshot 07: Return-Path header in Sublime Text

Finding 7: IP Address of the Sender's Email Server

X-Sender-IP is stamped by the receiving mail server not the attacker. That's what makes it reliable. The attacker can lie about their name and email address, but they cannot change what the receiving server recorded when the connection came in. This IP is the ground truth.

Sender IP Address	40.107.22.60
-------------------	--------------

```
69 X-Sender-IP: 40.107.22.60
```

Screenshot 08: X-Sender-IP header in Sublime Text

Finding 8: Resolved Hostname of the Sender's IP

I ran nslookup against the IP to resolve it to a hostname. A hostname often tells you who operates the server. If the email claims to be from Microsoft, the hostname should point to Microsoft infrastructure. If it doesn't, that's confirmation of impersonation.

nslookup 40.107.22.60

Resolved Hostname

mail-am6eur05on2060.outbound.protection.outlook.com

```
bigmyke@cyber-nonja:~/Downloads/SOC-FILE-RESOURCES/01_Phishing_Analysis/Challenges$ nslookup 40.107.22.60
60.22.107.40.in-addr.arpa      name = mail-am6eur05on2060.outbound.protection.outlook.com.
```

Authoritative answers can be found from:

```
bigmyke@cyber-nonja:~/Downloads/SOC-FILE-RESOURCES/01_Phishing_Analysis/Challenges$
```

Screenshot 09: nslookup output showing resolved hostname

Finding 9: Corporation That Owns the Sender's IP

WHOIS on the IP answers one simple question: who registered this address? It tells me the organization, country, and network block. That's how I confirm or disprove whether the server belongs to who the email claims to be from.

whois 40.107.22.60

IP Owner / Corporation

Microsoft Corporation

```
bigmyke@cyber-nonja:~/Downloads/SOC-FILE-RESOURCES/01_Phishing_Analysis/Challenges$ whois 40.107.22.60
#
# ARIN WHOIS data and services are subject to the Terms of Use
# available at: https://www.arin.net/resources/registry/whois/tou/
#
# If you see inaccuracies in the results, please report at
# https://www.arin.net/resources/registry/whois/inaccuracy_reporting/
#
# Copyright 1997-2026, American Registry for Internet Numbers, Ltd.
#

NetRange: 40.74.0.0 - 40.125.127.255
CIDR: 40.125.0.0/17, 40.96.0.0/12, 40.80.0.0/12, 40.76.0.0/14, 40.120.0.0/14, 40.74.0.0/15, 40.124.0.0/16, 40.112.0.0/13
NetName: MSFT
NetHandle: NET-40-74-0-0-1
Parent: NET40 (NET-40-0-0-0-0)
NetType: Direct Allocation
OrgInAS:
Organization: Microsoft Corporation (MSFT)
RegDate: 2015-02-23
Updated: 2021-12-14
Ref: https://rdap.arin.net/registry/ip/40.74.0.0

OrgName: Microsoft Corporation
OrgId: MSFT
Address: One Microsoft Way
City: Redmond
StateProv: WA
PostalCode: 98052
Country: US
RegDate: 1998-07-10
Updated: 2025-06-10
Comment: To report suspected security issues specific to traffic emanating from Microsoft online services, including the distribution
```

Screenshot 10: WHOIS output showing IP owner and corporation

Phase 3: Email Authentication Analysis (SPF)

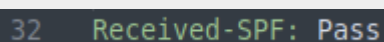
Why This Phase Matters: SPF Authentication

SPF tells you whether the sending server was authorized. What it doesn't tell you is whether the email is safe. A pass here just means the attacker's own domain is set up correctly. It says nothing about Microsoft. I had to read the result in context, not in isolation.

Finding 10: SPF Check Result

I searched for Received-SPF and Authentication-Results in Sublime Text. The key thing I learned here: SPF pass does not mean the email is legitimate. It means the sending server was authorized by whatever domain is in the From field. If that domain belongs to an attacker, SPF pass just means the attacker set up their infrastructure correctly.

SPF Result	Pass
------------	------

A screenshot of an email header line that reads "32 Received-SPF: Pass". The number "32" is in green and "Received-SPF: Pass" is in black.

Screenshot 11: SPF result in the Authentication-Results or Received-SPF header

Finding 11: Full SPF Record of the Sender's Domain

I queried the DNS TXT record for the sender's domain to pull the full SPF record. This tells me exactly which servers the domain authorises to send email on its behalf and explains why the SPF check produced the result it did.

For completeness: DKIM and DMARC both passed for the same domain social.helwan.edu.eg. All three authentication mechanisms confirm the attacker's domain, none of them confirm Microsoft.

```
nslookup -type=TXT social.helwan.edu.eg | grep -i "spf"
```

Full SPF Record	v=spf1 include:spf.protection.outlook.com -all
-----------------	--

A screenshot of a terminal window showing the command and output for the nslookup command. The command is "nslookup -type=txt social.helwan.edu.eg | grep -i 'spf'". The output is "social.helwan.edu.eg text = 'v=spf1 include:spf.protection.outlook.com -all'".

Screenshot 12: Full SPF TXT record output from nslookup

Phase 4: Message ID Analysis

Why This Phase Matters: Message ID

The Message-ID gives me a second, independent way to confirm the true origin without relying on the IP address. The domain after the @ symbol points straight to the sending server. It also means I can trace this same email across multiple recipients if needed.

Finding 12: Email Message ID

I searched for Message-ID in Sublime Text. The domain after the @ symbol is independently assigned by the originating server. It confirmed the same infrastructure I had already identified through the X-Sender-IP. Two separate data points, same origin that's corroboration.

Message-ID

JMrByPl2c3HBo8SctKnJ5C5Gp64sPSSWk76p4sjQ@s6

62 Message-ID: <JMrByPl2c3HBo8SctKnJ5C5Gp64sPSSWk76p4sjQ@s6>

Screenshot 13: Message-ID header in Sublime Text

Phase 5: Email Body and Encoding Analysis

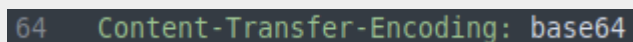
Why This Phase Matters: Content and Encoding Analysis

After the header, I looked at what the victim actually reads. But I also checked how the body was transmitted. Encoding matters because security filters scan for malicious keywords in plain text. If the body is encoded, those filters can miss the threat entirely. Deliberately.

Finding 13: Encoding Used to Transfer the Email Body

I searched for Content-Transfer-Encoding in Sublime Text. This header tells me how the body was packaged for transmission. The value matters because security tools often scan email content in plain text. Encoding the body is a way to get past those scans without triggering alerts.

Content-Transfer-Encoding	base64
---------------------------	--------

A screenshot of a Sublime Text editor window. The text '64 Content-Transfer-Encoding: base64' is visible in the editor. The '64' is in a light blue font, and the rest is in a dark blue font. The background is a light gray.

Screenshot 14: Content-Transfer-Encoding header in Sublime Text

Phase 6: URL Extraction and Analysis

Why This Phase Matters: URL Extraction and Analysis

The link is the payload. Everything else in the email exists to get Dana to click it. I extracted it safely using eioc.py and defanged it before documenting it, so it couldn't be accidentally activated. Then I submitted it to VirusTotal to get an objective verdict.

Finding 14: URL Extracted from the Email (Defanged)

I ran eioc.py against the .eml file to extract all URLs automatically. The script outputs them in defanged format dots and slashes replaced with safe equivalents. That means I can document the URL without any risk of accidentally activating it.

Two URLs were extracted. The first is a raw GitHub image link used to pull the Microsoft logo is benign infrastructure used to render the email's branding. The second is the malicious payload and was submitted to VirusTotal.

```
cd ~/01_Phishing_Analysis/tools
python3 eioc.py ../Challenges/challenge1.eml
```

**URL
(Defanged)**

```
hxxps[://]0[.]232[.]205[.]92[.]host[.]secureserver[.]net/lclb  
luewin08812/
```

Extracted URLs:

```
=====
hxxps[://]raw[.]githubusercontent[.]com/MalwareCube/SOC101/main/assets/01_Phishing_Analysis/microsoft[.]jpg
hxxps[://]0[.]232[.]205[.]92[.]host[.]secureserver[.]net/lclbluewin08812/
```

Screenshot 15: eioc.py output showing extracted and defanged URLs

Finding 15: VirusTotal Scan Results (Fortinet Verdict)

I re-fanged the URL, reversed the defanging, and submitted it to VirusTotal. The platform aggregates verdicts from dozens of security vendors. I specifically checked Fortinet's verdict, as required. The URL was never opened in a browser. VirusTotal handles the scanning through its own sandboxed infrastructure.

Note: The URL was re-fanged only for submission to VirusTotal. It was never opened directly in a browser. All analysis was performed through safe third-party scanning tools.

Fortinet Verdict

Phishing

VirusTotal Results Summary:

- **7/91**: total vendors flagged as phishing
- Fortinet verdict: **Phishing**

The screenshot displays the VirusTotal web interface for a specific URL. At the top, the browser address bar shows the URL: `https://0.232.205.92.host.secureserver.net/lclbluewin08812/`. The page header includes navigation links like 'Sign in' and 'Sign up'. The main content area features a 'Community Score' of 7/91, a status of 200, and a content type of 'image/png'. A table titled 'Security vendors' analysis' lists the results from various security vendors. The table shows that 7 out of 91 security vendors flagged the URL as malicious. The vendors listed are ADMINUSLabs, ESET, Fortinet, Sophos, CyRadar, Forcepoint ThreatSeeker, Kaspersky, and Abusix. Fortinet, ESET, and Sophos are all flagged as 'Phishing'. ADMINUSLabs is flagged as 'Malicious'. CyRadar, Forcepoint ThreatSeeker, and Kaspersky are also flagged as 'Phishing'. Abusix is flagged as 'Clean'. The interface also includes a 'Reanalyze' button and a 'Search' bar.

Security vendors' analysis	Do you want to automate checks?
ADMINUSLabs	Malicious
ESET	Phishing
Fortinet	Phishing
Sophos	Phishing
CyRadar	Phishing
Forcepoint ThreatSeeker	Phishing
Kaspersky	Phishing
Abusix	Clean

Screenshot 16: VirusTotal scan results showing Fortinet verdict

Final Verdict and Analyst Summary

VERDICT: THIS EMAIL IS NOT GENUINE
Classification: Phishing | Microsoft Outlook Impersonation

Here is what the evidence shows:

- Display name claims Microsoft. Actual sender address has no connection to Microsoft whatsoever
- X-Sender-IP resolves to Microsoft Exchange Online Protection infrastructure because the attacker's domain (social.helwan.edu.eg) routes its email through Microsoft 365. This is why SPF passed. The attacker didn't spoof Microsoft's servers they sent through them legitimately using a compromised or abused university account. SPF pass means nothing here without context.
- SPF passed for the attacker's own domain. That tells me nothing about Microsoft it tells me the attacker set up their sending infrastructure correctly
- Return-Path confirms the attacker controls the sending domain and is collecting delivery data
- Email body was encoded to avoid plain-text security scanning
- The embedded URL was flagged as phishing by multiple VirusTotal vendors, Fortinet included
- Fear, urgency, authority, and scarcity all four social engineering levers pulled in a single email
- 'Dear Customer' instead of Dana's name. This is a bulk campaign, not a targeted attack

Recommended Actions

- Block the sender domain at the email gateway
- Block the identified sending IP at the firewall level
- Submit the malicious URL to the email gateway blocklist
- Run a message trace on the email gateway to identify any other employees who received the same email
- Alert Dana Derringer that the email is phishing and advise her not to click any links
- If any employee clicked the link, escalate to incident response immediately

Findings Summary Table

This table maps each finding to its evidence type, the tool used, and why it matters for the overall verdict.

#	Finding	Evidence Type	Tool	Significance
1	Date and Time of Delivery	Email Header	<i>Sublime Text</i>	Timestamps the attack precisely
2	Subject Line	Email Header	<i>Sublime Text</i>	Fear and urgency tactic to prompt action
3	Recipient Email Address	Email Header	<i>Sublime Text</i>	Confirms intended target
4	Display Name (Claimed Identity)	Email Header	<i>Thunderbird</i>	Impersonation of trusted brand
5	Actual Sender Email Address	Email Header	<i>Sublime Text</i>	Exposes spoofed identity
6	Bounce Address (Return-Path)	Email Header	<i>Sublime Text</i>	Reveals attacker-controlled infrastructure
7	Sender Server IP Address	Email Header	<i>Sublime Text</i>	True origin — cannot be faked by attacker
8	Resolved Hostname of Sender IP	Reverse DNS	<i>nslookup</i>	Confirms sender's server identity
9	IP Owner / Corporation	OSINT	<i>whois</i>	Verifies or disproves claimed identity
10	SPF Check Result	Authentication	<i>Sublime Text</i>	Pass ≠ legitimate — context required
11	Full SPF Record of Sender Domain	DNS Query	<i>nslookup</i>	Confirms why SPF result was produced
12	Message ID	Email Header	<i>Sublime Text</i>	Independent corroboration of true origin
13	Content-Transfer-Encoding	Email Header	<i>Sublime Text</i>	Encoding used to evade security filters
14	URL Extracted from Email (Defanged)	IOC Extraction	<i>eioc.py</i>	Malicious link embedded in email body
15	VirusTotal / Fortinet Verdict	Threat Intel	<i>VirusTotal</i>	External confirmation of malicious URL

Tools Used in This Analysis

Tool	Purpose
<code>Thunderbird</code>	Opened the .eml file and rendered it visually, exactly as the victim would have seen it
<code>Sublime Text</code>	Opened the raw .eml file to display and inspect the complete email header
<code>nslookup</code>	Performed reverse DNS lookup on the sender's IP and queried the SPF TXT record of the sender's domain
<code>whois</code>	Queried the registered owner, organization, and country of the sender's IP address
<code>eioc.py</code>	Extracted all URLs and indicators of compromise from the raw .eml file in defanged format
<code>VirusTotal</code>	Scanned the extracted URL to determine its reputation and malicious classification across multiple security vendors

— End of Report —